

YGREKY

Introduction to the Cyber Resilience Act

For embedded developers, 15/12/2025

Marta Rybczynska

About this webinar

YGREKY

- Overview of the Cyber Resilience Act (CRA)
  - For embedded developers
  - Assumes technical knowledge
  - Up to date as of 15/12/2025
- Slides and the video will be available
- Part of the “Embedded Security” course
  - Refresher for past participants
  - More about the course: https://ygreky.com/embedded-security-yp/
- Not legal advice
  - Current understanding of the situation only - and may change

Scope of this webinar

YGREKY

- This webinar is designed for embedded developers
  - Legal terms “translated” to developer-speak
  - Ask for a professional legal advice when in doubt
- Selection of topics
  - Most important (in Marta’s opinion) subjects
  - We do not cover importers and distributors
  - We do not cover details on standardization
  - We do not cover interactions with other legislations (and legal framework like the “Blue Guide”)

Who is Marta Rybczynska?

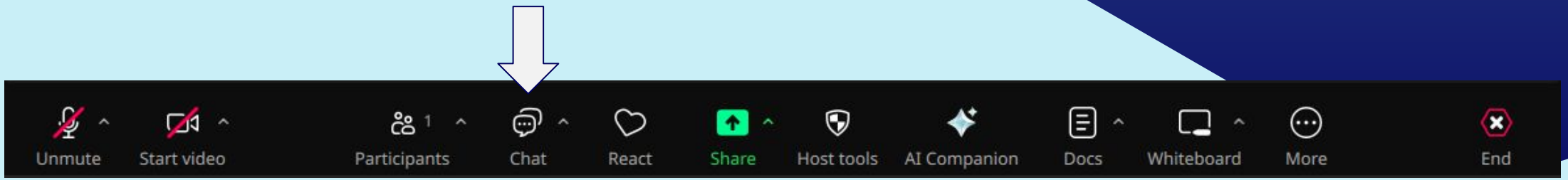
YGREKY

- PhD in Telecommunications
  - Network security/anonymity systems
- Open source/embedded developer/architect
  - 20+ years in open source
  - Contributions to the Linux kernel, various RTOSes
  - Co-maintainer of meta-security YP layer
  - Yocto Project security team and Open Embedded Technical Steering Committee member
- Founder/CEO of Ygreky
  - Consulting (processes, architecture, audits)
  - Technical writing
  - Teaching (“Embedded Security”, webinars)
  - Current contribution to CRA-related standardisation
  - Conference keynotes



YGREKY

During the session, post your questions in the chat



Multiple regulations on cybersecurity

YGREKY

- Europe
  - Cyber Resilience Act (CRA)
  - Product Liability Directive (PLD)
  - AI Act
- Similar in other places
  - USA, UK...
  - Asia - work in progress
- Mandatory - not recommendations
- Wider scope than previous regulations

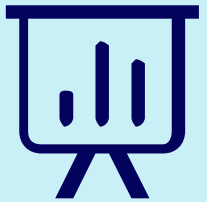
Motivation (CRA's first paragraph)

Cybersecurity is one of the key challenges for the Union. The number and variety of connected devices **will rise exponentially** in the coming years. **Cyberattacks represent a matter of public interest** as they have a **critical impact** not only on the Union's **economy**, but **also on democracy** as well as **consumer safety and health**. It is therefore necessary to strengthen the Union's approach to cybersecurity, address cyber resilience at Union level and improve the functioning of the internal market by laying down a uniform legal framework for essential cybersecurity requirements for placing products with digital elements on the Union market. **Two major problems** adding costs for users and society should be addressed: **a low level of cybersecurity** of products with digital elements, reflected by widespread vulnerabilities and the insufficient and inconsistent provision of security updates to address them, and an **insufficient understanding and access to information by users**, preventing them from choosing products with adequate cybersecurity properties or using them in a secure manner.

Basic facts

- **Mandatory security requirements for all hardware and software products placed on the market in the EU**
- **Extending the “CE” marking to software**
- **Obligations for “manufacturers” and other actors: due diligence for all components**
- **Mandatory conformity assessment - based on risk**
- **Implementation will use multiple standards - work in progress**
- **Special handling for FLOSS (not monetized) - self assessment except for critical products**

YGREKY



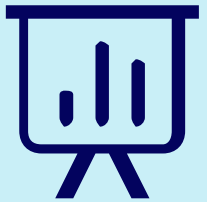
User visible changes: the support period

What is the support period?

YGREKY

- The period when security updates are available
  - Security updates free of charge
  - Fixes/mitigation of found vulnerabilities
  - User information about fixed vulnerabilities
- Defined for each product
  - By the manufacturer
- Should correspond to the product lifetime
  - By default minimum of 5 years
  - Starts when the item is sold by the manufacturer

YGREKY



Which products are in scope?

Which products are in scope?

YGREKY

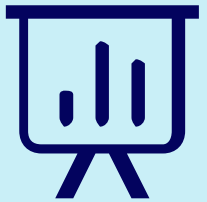
- Definition
  - *‘**product with digital elements’** means a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately;*
- Nearly all hardware/software embedded products
  - Sold/placed on the market in the European Union
  - Doesn’t matter where designed or produced
- Including remote processing
  - If needed for the functionality -> part of the product
- Pure software (downloaded apps) or pure hardware - included
- Firmware - included

Which products are in scope?
In and out of scope - examples

YGREKY

- In scope
  - Embedded devices with logical/physical network connection
    - Coffee machine with an app to control it or install updates - in scope
    - A mesh sensor with Bluetooth connectivity
  - Devices with remote processing
    - Home automation with an app and remote dashboard - devices, the app, and the remote processing all in scope
- Out of scope
  - When there is no physical or logical connection to other devices
    - Coffee machine with no network/no app connection - out of scope
  - When there is other regulation in place and direct exclusion from the CRA (eg. most medical devices, automotive)
  - Hobby projects
  - Not monetized open source
  - SaaS (Software as a Service) and websites

YGREKY



CRA actors: manufacturers, open source stewards and others

Who is a manufacturer?

YGREKY

- Definition
  - *A natural or legal person who **develops or manufactures** products with digital elements or has products with digital elements designed, developed or manufactured, and **markets them under its name or trademark**, whether for payment, monetisation or free of charge.*
- Embedded device vendors clearly in scope
- No minimum turnover or number of employees

Open Source Stewards

- **Special case for FOSS**
- **“Provide support on sustained basis [...] and who play a main role in ensuring the viability of those products”**
- **Less obligations**
- **... but no CE marking on the product!**

The Open Source exception (1)

YGREKY

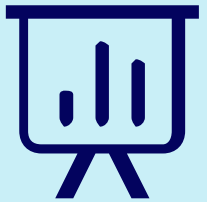
- Recital 18:
  - *“[...]only free and open-source software made available on the market, and therefore supplied for distribution or use in the course of a commercial activity, should fall within the scope of this Regulation. [...] Furthermore, the supply of products with digital elements qualifying as free and open-source software components intended for integration by other manufacturers into their own products with digital elements should be considered to be making available on the market only if the component is monetised by its original manufacturer.[...]”*

The Open Source exception (2)

YGREKY

- No obligations under the CRA
  - Contributors to open source projects
  - Non-profits (but may be open source stewards)
  - Companies contributing to open source projects hosted by others, when they do not monetize that project
- Unclear
  - Companies hiring open source maintainers, eg. charging for support, custom development
  - Companies owned by open source maintainers, eg. charging for support, custom development
- More clarification expected in “Open Source FAQ”

YGREKY



Product type classification

CRA product classification

YGREKY

General case: self-assessment

Important products with digital elements: application of standards or third party assessment

Multiple categories including:
Identity management systems software (class I)
Operating systems (class I)
Physical and virtual network interfaces (class I)
Hypervisors and containers environments (class II)
FIrewalls, intrusion detection (class II)

Critical products: third party assessment, certification in the future

3 categories:
Hardware devices with security boxes
Smart meter gateways
Smartcards or similar devices

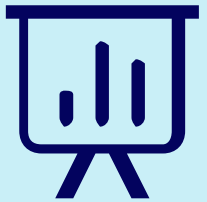
Which category is my product?

YGREKY

- The main function matters
  - Called “core functionality”
  - The product does not “inherit” the category from a component
- Most products will be the “generic” category
  - Self-assessment only
- Official definitions have been published
  - Implementation regulation 2025/2392 of 28 November 2025 https://eur-lex.europa.eu/eli/reg_impl/2025/2392/oj/eng
- Example:

8. Boot managers	Software products with digital elements that manage the process of initial system startup after power on/restart by initialising hardware, loading or transferring control to the operating system environment or system resources, and selecting boot options. This category includes but is not limited to UEFI firmware, single-stage and multi-stage boot loaders.

YGREKY



Requirements

CRA Requirements (1)
Product-related

YGREKY

- Information for the user (Annex II)
  - Identification, support period, how to report vulnerabilities
  - Information on how to use securely, how to install updates...
  - Software Bill of Materials (optional)
- Technical documentation (Article 31 and Annex VII) - kept for 10 years or the support period (whichever is longer)
  - Architecture, design information, vulnerability handling process
  - **Risk assessment**
  - How the support period has been calculated
  - List of standards that have been applied
  - SBOM on request
- Simplified technical documentation for small companies - not defined yet

CRA Requirements (2)

YGREKY

- Vulnerability management
  - Documented contact method
  - Coordinated disclosure
  - Security Fixes distributed to user “free of charge”
  - Mandatory notification of affected upstream
- Mandatory reporting
  - Exploited vulnerabilities
  - Security incidents
- Voluntary reporting of all fixed vulnerabilities

Self-assessment, Annex I

Products with digital elements shall be **designed**, **developed** and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks;

YGREKY

Self-assessment, Annex I: Requirements if risk analysis confirms them (reworded)

- Release **without known vulnerabilities**
- **Secure by default configuration**
- **Update function mandatory** (including automatic, opt-out function, user notifications)
- **Access control**, reporting on unauthorised access
- **Confidentiality of data** processed, stored, transmitted
- Protect against data corruption or manipulation not authorised by the user
- Minimisation of data
- Resilience and protection against denial-of-service
- Minimise negative impact of the product to other services
- **Be designed, developed and produced to limit attack surfaces, including external interfaces**
- **Be designed, developed and produced to reduce incident**
- Recording relevant internal activity (with opt-out for the user)
- Possibility for the user to remove all data permanently

Self-assessment, Annex I: Vulnerability handling (reworded)

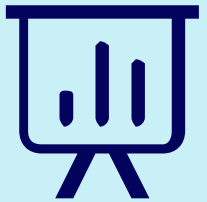
- Identify and document vulnerabilities (including software bill of materials)
- Remediate vulnerabilities **without delay** (functional updates separate from security updates)
- **Perform tests and reviews** of the security of the product
- **Publicly disclose information** about fixed vulnerabilities (including impact, severity)
- Put in place coordinated vulnerability disclosure
- Distribute updates securely
- Release security updates without delay, **free of charge**

Embedded developers' challenges
Marta's opinions

YGREKY

- The CRA is risk-based
  - Risk assessment hasn't been a typical practice in embedded until now
  - … and it doesn't force any specific methodology (which is good IMO)
  - Risk analysis seems to be the main document of conformance defense
- No checklist of technical methods
  - Requires architecture work
  - Requires cross-team work
- No "test cases" and past experiences of that scope
  - We do not know what is "good enough"

YGREKY



Timeline

CRA Obligations



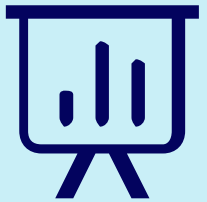
- All obligations apply: 11 December 2027
- Creation of standards: 2026
- Reporting of exploited vulnerabilities and security incidents: September 2026

CRA Recent Advancements



- Definition of important/critical product classes
- The official FAQ
- 1st review of two main horizontal standards finished, third review (vulnerability management) starting now
- Vertical standards (by product type) mostly available for review (at different stages)

YGREKY



Wrapping up

Marta’s recommendations

YGREKY

- It is the time to start preparations!
- Even if you have perfect security practices, there’s documentation to write
  - User documentation
  - Product technical documentation
- Much information online
  - Frequently outdated! -> Check the publication date (older publications may cover one of the CRA drafts)
  - Many misconceptions still -> Check the legal text (and/or your lawyer) when in doubt

Resources list

YGREKY

- The CRA legal text
  - https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L_202402847
- Product category definitions
  - https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L_202502392
- The official CRA FAQ (there will be more)
  - https://digital-strategy.ec.europa.eu/en/factpages/cyber-resilience-act-implementation
- Open source-focus organizations working on the CRA
  - OpenSSF
  - ORC WG (Open Regulatory Compliance)

Second part of the webinar

YGREKY

- “The Current State of the CRA for embedded developers”
  - Wednesday December 17th, 15h CET
  - If not registered, you can do it at https://ygreky.com/2025/12/understanding-the-cyber-resilience-act/
- Content
  - Standardization status (horizontal and vertical standards)
  - What is the “presumption of conformity”?
  - What documentation you will need?
  - What is still unclear?

Questions?

